

Protect Amazon SP-API Applications with Incident Response ↕

[🏠 Home](#)[📖 Documentation](#)[<> API Reference](#)[🔗 Code Samples](#)[📢 Announcements](#)[Models](#)[Release Notes](#)[FAQ](#)[GitHub](#)[Videos](#)

GET STARTED

- Welcome to SP-API Documentation
- What is the Selling Partner API?
- Selling Partner API Onboarding Overview >

Protect Amazon SP-API Applications with Incident Response

Incident response measures to protect Amazon SP-API applications.

This guide outlines guidance on what constitutes an incident response plan and the mechanisms required to handle an incident. A well-documented incident response plan helps you identify, detect, and respond to risk management failures quickly. The plan should be regularly reviewed and revised to facilitate immediate incident handling and incorporate lessons learned.

Amazon Data Protection

[Terminology](#)[Frequently Asked Questions](#)

CHANGELOG

[SP-API Release Notes](#)[SP-API Deprecation Schedule](#)[SP-API Product Metadata Updates](#)

DIRECTORIES

[SP-API Models](#)[SP-API Seller Use Cases](#)[SP-API Vendor Use Cases](#)[Seller Central URLs](#)[Vendor Central URLs](#)

REGISTRATION

[SP-API Registration Overview](#)[Developer Registration Request Status](#)[Third-Party Provider Registration](#)[Service Provider Registration and Role Approval Process Overview](#)[Website Guidelines for Public Developers and Service Providers](#)[User Permissions for Service Providers](#)[Register your Application](#)[Update your Application Information](#)[Rotate your Application's LWA Credentials](#)[View your Application Information and Credentials](#)[Learn How Sellers Authorize Service Providers](#)[Selling Partner API Roles](#)

Policy (DPP) requirements

The Amazon Data Protection Policy contains two categories related to security requirements:

- **Section 1. General Security Requirements,** which includes requirements for all Solution providers building SP-API applications.
- **Section 2. Additional Security Requirements for Personally Identifiable Information (PII),** which includes additional requirements for Solutions providers performing restricted operations on SP-API that involve personally identifiable information (PII).

To comply with the **Incident response** requirements in the DPP, Solution providers must:

- Maintain thorough incident response plans approved by senior management and

Policies and Agreements		reviewed every six months and updated after major
About Facial Data		infrastructure changes or lessons learned.
AUTHORIZATION		
Authorize Applications	>	• Include all standard incident response phases (preparation, identification, containment, eradication, recovery, lessons learned) with specific procedures for different incident types.
Renew Authorizations		
Revoke Authorizations		
Authorization Limits		
Special Authorization Types	>	• Establish annual risk assessment and management processes reviewed by senior management and document roles, responsibilities, and decision-making authority for all team members.
INTEGRATION		
Building Robust Amazon SP-API Applications		
SP-API SDKs	>	• Designate an Incident Management Point of Contact (IMPOC) and maintain current IMPOC contact details. • Maintain updated contact lists with clear internal escalation paths and notify Amazon at security@amazon.com within 24 hours

of detecting security incidents.

Delete an Application From Your Developer Account

- Establish procedures for notifying government agencies as required by law and create customer communication protocols for incident status updates.

CALLING THE SP-API

Configuration Details >

Call Structure >

Development Tools >

Performance Management >

Incident response

Solution providers should understand security incident response (IR) processes, and security staff should understand how to respond to security issues. Solution providers without a dedicated security team should ensure a portion of the organization is sufficiently trained and equipped with tools to perform such activities. Alternatively, they should consider establishing a dedicated security team. Solution providers who wish to build a mature security team should consider this best practice: integrate the flow of security events and findings into a notification and

SOLUTION PROVIDER PORTAL

Manage Users in Solution Provider Portal

Manage Your Business And Contact information in Solution Provider Portal

Update Your Developer Profile in Solution Provider Portal

Unify Your Developer Accounts

Verify Your Identity in Solution Provider Portal

API Usage Metrics in Solution Provider Portal

TUTORIALS

Tutorial: Subscribe to the ORDER_CHANGE Notification

Tutorial: Test Selling Partner API Endpoints

Tutorial: Automate your SP-API Calls Using a C# SDK

Tutorial: Automate your SP-API Calls Using a Java SDK

Tutorial: Automate your SP-API Calls Using a JavaScript SDK for Node.js

Tutorial: Automate your SP-API Calls Using a Python SDK

Tutorial: Automate your SP-API Calls using a prebuilt C# SDK

Tutorial: Automate your SP-API Calls using prebuilt Java SDK

Tutorial: Automate your SP-API Calls using a prebuilt JavaScript SDK

Tutorial: Automate your SP-API Calls using prebuilt PHP SDK

Tutorial: Automate your SP-API calls using a prebuilt Python SDK

Tutorial: Authorize Multiple Vendor Central Accounts with a Single SP-API Application

Tutorial: Retrieve Merchant Shipping Templates

Tutorial: Grant the SP-API Permission to an Amazon SQS Queue

Tutorial: Retrieve and Pass a Purchase Order Number to a Carrier

TROUBLESHOOTING

Troubleshoot SP-API Errors

URL Encoding

Resolve Common HTTP and Authorization Error Codes

External Fulfillment Errors



Listings Items API Issues Troubleshooting



SELLING PARTNER APPSTORE

What is the Selling Partner Appstore?

List Your App on the Selling Partner Appstore

Edit Your Appstore Listing

Check Listing Status

Appstore Ratings and Reviews

Press Releases and Promotions

SERVICE PROVIDER NETWORK

List Your Service

SECURITY AND COMPLIANCE

SP-API Security and Compliance Overview

workflow system. Such systems include ticketing systems, a known/technical issue system, or other security information and event management (SIEM) system.

Solution providers should start small, develop runbooks, leverage functional capabilities, and create a library of incident response mechanisms to iterate from and improve upon. This should include teams that are not involved with security, including the legal department. This cross-functional approach helps Solution providers understand how IR impacts business objectives.

Solution providers should consider using industry guidelines such as the [Incident Response Recommendations and Considerations for Cybersecurity Risk Management, A CSF 2.0 Community Profile](#).

This NIST guide includes a checklist of major incident response steps that Solution providers can use as a template when developing their plan. They may develop a specific plan to reflect

Amazon Selling Partner API Guard Implementation Guide



the organization's functions, objectives, risks, and mitigating actions. Each of these is dependent upon the size and complexity of the organization and its systems.

VAT Calculation Service



Throughout this guide, we refer to the United States' National Institute of Standards and Technology's (NIST) Security and Privacy Controls for Information Systems and Organizations (Special Publication 800-53 Revision 5), commonly referred to as *NIST 800-53* as a reference. This developing framework provides flexible controls to protect organizations from security and privacy threats. Solution providers should consider using this framework to implement and strengthen their organizational controls.

Amazon Seller Data Access

Best Practices



Key Security Control Guidance

Logging and Monitoring for Amazon SP-API Applications

Network Protection Guidance

Protect Amazon API Applications with Data Encryption

Protect Amazon API Applications with Data Retention and Recovery

Protect Amazon SP-API Applications with Incident Response

Safeguarding Sensitive Credentials

Vulnerability Management

Foundation of incident response

Incident response plans, often referred to as procedures or runbooks, define the steps to investigate and remediate an incident. Experience and

A+ CONTENT API

A+ Content API



A+ Content Examples		education are vital to implementing an incident response program before handling a security event.
AMAZON WAREHOUSING AND DISTRIBUTION API		
Amazon Warehousing and Distribution API	>	An event is any occurrence in a system or network, ranging from acceptable events (e.g., a known user logging into a computer) to an adverse event (e.g., an unknown user logging into a computer).
Amazon Warehousing and Distribution API v2024-05-09 Reference		Adverse events can escalate into incidents that violate computer security policies, acceptable use policies, or contractual requirements.
APP INTEGRATIONS API		
App Integrations API	>	Solution providers who wish to use NIST 800-53 to establish an IR plan may examine section IR-8: Incident Response Plan . IR-8 details the necessary components in implementing an IR plan. Such components include:
APPLICATION MANAGEMENT API		
Application Management API	>	• Defining the resources and management support needed.
CATALOG ITEMS API		
Catalog Items API	>	• Reviewing and approving the plan at a defined cadence.
Catalog Items API Rate Limits		
Catalog Items API v2022-04-01 Reference		
CUSTOMER FEEDBACK API		
Customer Feedback API	>	• Designating responsibility for IR

Customer Feedback API Rate Limits

to appropriate
personnel.

DATA KIOSK

Data Kiosk API

>

By implementing this control, Solution providers can achieve compliance with Amazon DPP requirements. This includes reviewing and verifying the plan every six months and informing Amazon within 24 hours of detecting any incidents.

Data Kiosk Schema Explorer User Guide

Data Kiosk Query Processing Finished Notification

Building Data Kiosk workflows guide

Vendor Analytics Dataset Use Case Guide

Schedule Data Kiosk Queries

DELIVERY BY AMAZON API

Delivery by Amazon API

>

Incident Management Point of Contact (IMPOC)

EASY SHIP API

Easy Ship API

>

Solution providers must identify and designate an Incident Management Point of Contact (IMPOC) who can be reached in the event of any incident, such as a data leakage or security breach. The IMPOC serves as a readily available contact for Amazon to reach out to when security incidents are identified.

EXTERNAL FULFILLMENT

External Fulfillment Inventory API

>

External Fulfillment Returns API

>

IMPOC requirements

External Fulfillment Shipping API

>

Solution providers must ensure their designated IMPOC:

- Is readily available and accessible for

External Fulfillment Errors

External Fulfillment APIs Rate Limits

incident communications.

FULFILLMENT BY AMAZON (FBA)

FBA Inventory API

>

- Has the authority and knowledge to coordinate incident response activities.

FBA Inventory Dynamic Sandbox Guide

FEEDS API

Feeds API

>

- Can be contacted quickly in the event of data leakage or security breach events.

Feed Type Values

>

- Maintains current contact information (name, email, and phone number) that is shared with Amazon.

Feeds JSON Schemas

↗

Feeds API Best Practices

Feeds API FAQ

Feeds API Rate Limits

The IMPOC designation is a critical component of the incident response framework and helps ensure timely communication and coordination when security incidents occur.

FINANCES

Finances API

>

Security events

A well-defined incident response plan includes response mechanisms for different types of security events.

Solution providers should consider using diagrams to map the relationship between threats and the appropriate response mechanisms. For example, the Johari Window, created in

Transfers API

>

FULFILLMENT INBOUND API

Fulfillment Inbound API

>

1955 by Joseph Luft and Harrington Ingham, is a grid that consists of four quadrants, as depicted below:

	Known to You	Not Known to You
Known to Others	Obvious	Blind Spot
Not Known to Others	Internally Known	Unknown

Types of security events

The Johari Window provides a useful framework for Solution providers to assess and categorize organizational threats. For incident response purposes, the four quadrants represent: Obvious, Internally Known, Blind Spot, and Unknown threats. For each incident type, Solution providers should define response procedures to ensure adequate preparation. As Solution providers define those types, they should consider the threats relevant to both partners and suppliers. Include contact information and identify the point at which the tools and systems notify personnel within the organization. This is required to comply with service level agreements in regulatory and

- Fulfillment Inbound API FAQ
- Migrating Fulfillment Inbound workflows
- Fulfillment Inbound API Rate Limits

FULFILLMENT OUTBOUND API

- Fulfillment Outbound Dynamic Sandbox Guide
- Fulfillment Outbound API



contractual obligations,
including with Amazon.

Obvious

Obvious threats are risks of which both Solution providers and their partners, such as Amazon, are aware. For example, malicious actors commonly employ Denial of Service (DoS) attacks against organizations. In a DoS attack, a malicious actor temporarily or indefinitely disrupts the application's availability. Solution providers should employ mechanisms to protect services from intentional malicious interruption. Solution providers should consider defining minimally acceptable downtime recovery goals for DoS attacks.

Malicious actors commonly attempt to invade, and even control, organizations by intruding into their applications. Solution providers can mitigate intrusion attempts by implementing Intrusion Prevention Systems (IPS) and Intrusion Detection Systems (IDS). Each system examines network traffic flows to detect if an intruder is

Fulfillment Outbound API Rate Limits

MCF Best Practices

INVOICING

Invoices API

>

Invoices API FAQ

LISTINGS

Listings Items API

>

Listings Items API Rate Limits

Listings Restrictions API

>

Listings Restrictions API Rate Limits

Manage Product Listings with the Selling Partner API

Building Listings Management Workflows Guide

Understanding Amazon listing status and seller-fulfilled inventory management

Listings Management Workflow Migration

>

Manage Amazon Haul, Advanced Multiple-Offer, and Multiple-Fulfillment Use Cases

Listings APIs FAQ

Product Type Definitions API

>

attempting to access the system. In the case of an IPS, the system prevents unauthorized users from entering. However, if an intrusion is successful, an IDS sends a notification to trigger a response.

Internally known

Internally known threats are those that the Solution providers are familiar with, but their partners (such as Amazon) are not. This includes internal expertise or institutional knowledge. For example, the development team may have established but undocumented practices for managing configuration changes, which creates risks. For example, the team:

- Might not be confident that all changes are tested and approved.
- Might not have rollback mechanisms in case code releases did not work as intended.
- Might not scan for technical issues in new production releases.

Product Type Definitions API Rate Limits

MERCHANT FULFILLMENT API

Merchant Fulfillment API

>

MESSAGING API

Messaging API

>

NOTIFICATIONS API

Notifications API

>

Notification Type Values

Tutorial: Subscribe to the ORDER_CHANGE Notification



Solution providers should consider these scenarios to mitigate internally known threats.

ORDERS API

Orders API



Additionally, insider risks, such as an employee's malicious or unintentional action, might harm the environment. Access management controls and data loss prevention mechanisms help prevent and detect such actions. Limiting unauthorized data access, both from internal and external entities, is a critical step in securing and protecting data.

Tutorial: Retrieve and Pass a Purchase Order Number to a Carrier



Solution providers should employ the principle of least privilege—granting only the access

Orders API Migration Guide

Orders API Rate Limits

PRODUCT FEES API

Product Fees API



necessary for each person or program to complete their respective tasks. It is best practice to delete default access accounts and limit the use of shared accounts. If necessary, Solution

PRODUCT PRICING API

Product Pricing API



providers should monitor shared accounts to validate that they are only used when necessary. Shared accounts should only be shared after the appropriate administrators approve their use. Solution

Product Pricing API and Notifications FAQ

Price Adjustment Automation Workflows Guide

Manage automated pricing rules with SP-API

REPLENISHMENT API

Replenishment API

- > providers may supplement these monitors with data loss prevention controls. This prevents inadvertent sharing of confidential or critical information with unauthorized parties.

REPORTS API

Reports API

- > That information may even include encryption keys or application credentials (e.g., embedded in code and exposed in GitHub) that can bypass the controls.

Report Type Values

- > **Blind spot**
Blind spots are risks that a partner is familiar with, but Solution providers are not. A partner with the right expertise can share that knowledge. Such risks may be Common Vulnerabilities and Exposures (CVEs) that affect applications without the owner's knowledge. Although Solution providers may know these risks exist, partners can recommend specific controls and solutions they have not considered. Additionally, a partner may be equipped to identify fine-tuned controls for mitigating risks in the internally known quadrant.

Reports JSON Schemas

Reports API FAQ



SALES API

Sales API



SELLER WALLET API

Seller Wallet API	>	Other blind spots include the changing regulatory environment. The European Union's General Data Protection Regulation (GDPR) affects businesses worldwide, and similar regulations, such as the California Consumer Privacy Act (CCPA), are quickly arising. Such regulations can affect response mechanisms and notification methods.
Seller Wallet API Rate Limits		
SELLERS API		
Sellers API	>	
SERVICES API		
Services API	>	
		Monitoring the external environment helps mitigate these risks. Specifically, the National Vulnerability Databases (NVDs) helps organizations understand the latest vulnerabilities and their risk scores. Such scores, led by the Common Vulnerability Scoring System (CVSS), enumerate a technical issue's severity, taking into account its complexity and impact. Solution providers should stay abreast of industry updates, regulatory changes, and contractual requirements. Requirements change frequently and may require Solution providers to improve internal processes to
SHIPMENT INVOICING API		
Shipment Invoicing API	>	
SHIPPING API		
Shipping API v2 Resources	↗	
Shipping API v1 Reference		
SOLICITATIONS API		
Solicitations API	>	
SUPPLY SOURCES API		
Supply Sources API	>	

Multi-Location Inventory Integration Guide

Supply Sources API Rate Limits

TOKENS API

Tokens API



remain compliant. Solution providers should meet with partners regularly to understand blind spots and mitigate them. To improve their security posture, Solution providers may contact Amazon using the [Amazon Services Support page](#).

Unknown

Unknown threats are risks which neither Solution providers nor their partners are familiar with. Implementing and reviewing monitoring mechanisms can identify indicators of security events.

UPLOADS API

Uploads API



VEHICLES API

Vehicles API



Vehicles API Rate Limits

VENDOR DIRECT FULFILLMENT APIS

Vendor Direct Fulfillment Dynamic Sandbox Guide

Vendor Direct Fulfillment Workflow Guide

SP-API Bill-to-Party Addresses

VENDOR DIRECT FULFILLMENT TRANSACTION STATUS API

Vendor Direct Fulfillment Transaction Status API



Indicators of security events

Solution providers should investigate all security events to ensure that they do not develop into security incidents. Though not exhaustive, Solution providers should consider the following list of potential indicators of security events:

- **Logs and monitors.** A sudden change in computing activity, as indicated by

VENDOR DIRECT FULFILLMENT INVENTORY API

Vendor Direct Fulfillment Inventory API	>	monitoring tools and logs, can indicate a security event.
VENDOR DIRECT FULFILLMENT ORDERS API		
Vendor Direct Fulfillment Orders API	>	• Unusual billing activity. A sudden increase in billing activity can indicate a security event. This billing activity might arise from compute-intensive processes that an intruder might initiate, such as bitcoin mining.
VENDOR DIRECT FULFILLMENT SHIPPING API		
Vendor Direct Fulfillment Shipping API	>	• Threat intelligence feeds. If your organization subscribes to a third-party threat intelligence feed, correlate that information with other logging and monitoring tools to identify potential indicators of events.
VENDOR DIRECT FULFILLMENT PAYMENTS API		
Vendor Direct Fulfillment Payments API	>	• Data integrity. Data in a service or application returns unexpected values.
VENDOR RETAIL PROCUREMENT INVOICES API		
Vendor Retail Procurement Invoices API	>	• Data exposure. Sensitive data is exposed to unauthorized or unintended parties.
VENDOR RETAIL PROCUREMENT ORDERS API		
Vendor Retail Procurement Orders API	>	• Lack of availability. An application or

VENDOR RETAIL PROCUREMENT SHIPMENTS API

Vendor Retail Procurement Shipments API >

service cannot fulfill its functions.

VENDOR RETAIL PROCUREMENT TRANSACTION STATUS API

Vendor Retail Procurement Transaction Status API >

Powered
by

- **Public-facing security contact mechanism.** A well-known, well-publicized method of contacting the security team can inform Solution providers of an incident. Customers, the development team, or other staff might notice and report something unusual. Solution providers who work with the general public might need to develop a public-facing security contact mechanism, such as a contact email address or a web form.
- **System alerts.** Internal systems may generate notifications that alert in case of unusual, malicious, or expensive activities. For example, Solution providers may create a notification for activities that occur outside of expected time frames.

- **Machine learning.**
Solution providers can leverage machine learning to identify complex anomalies for a specific organization or individual person. Solution providers can profile the normal characteristics of the networks, users, and systems to help identify unusual behaviors.

Define roles and responsibilities

Incident response skills and mechanisms are vital when handling new or large-scale events. Handling unclear security events requires cross-organizational discipline, decisive action, and the ability to deliver results.

Solution providers should work with stakeholders, legal counsel, and organizational leadership to identify goals in responding to an incident. Some common goals include containing and mitigating the issue, recovering the affected

resources, preserving data for forensics, and attribution. Solution providers should consider these roles and responsibilities, and whether any third parties should be involved. All incident documentation, including incident descriptions, remediation actions, and associated corrective controls, must be made available to Amazon upon request.

List of security stakeholders:

- **Incident Management Point of Contact (IMPOC).** The designated IMPOC serves as the primary contact for Amazon in the event of security incidents, data leakage, or security breaches. This individual must be readily available and have the authority to coordinate incident response activities across the organization.
- **Application owners.** Solution providers might need to contact owners of

impacted applications or resources because they are subject matter experts (SMEs) that can provide information and context.

Application owners or SMEs might be required to act in situations where the environment is unfamiliar, has unanticipated complexity, or where the responders do not have access. SMEs should participate in incident response exercises and establish working relationships with the IR team.

- **Information security.** The Information Security team is the primary contact point when an event or incident is identified. They can respond by investigating, remediating, and preventing incidents from occurring.
- **Legal.** The Legal team provides guidance in understanding any

legal impacts a security incident may have. This includes crafting communication for all affected parties, including contractors, service providers, customers, and regulatory authorities.

- **Chief, Business, and Information Security Officers.** Information security leadership, including the Chief Information Security Officer (CISO) need to remain abreast of the Solution providers' security health. In coordination with the Information Security and Legal teams, the CISO leads the organization to prevent, detect, remediate, and communicate incident response in accordance with laws and best practices.
- **The rest of the organization.** The overall organization should be aware of potential risks and appropriate reporting

mechanisms.

Information

security awareness

training can help

the staff (technical

and non-technical)

prevent security

events from

occurring, identify

indicators of

incidents, and

report potential

incidents to the

security team.

- **Third parties.**

Trusted partners

can help in

investigation and

response,

providing

additional

expertise and

valuable scrutiny.

Such partners

include third

parties who

contractually

require notification

that an incident

occurred.

Specifically,

Solution providers

must inform

Amazon at

security@amazon.com within 24 hours

of detecting any

security incidents.

Alternatively,

service providers

might specify in

their terms and

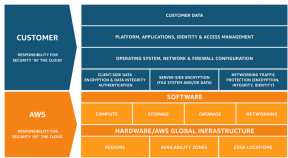
conditions which

information

security areas they

are responsible for.

Such providers or partners might include Cloud Service Providers (CSPs) who own a portion of the security responsibilities within the environment. The following figure shows a typical representation of the shared responsibility model as it applies to AWS. AWS owns the security OF the cloud, providing the highest levels of security possible. Their customers are responsible for the security of their resources in the cloud, keeping its content secure and compliant.



Notification and response

Solution providers should notify appropriate parties, such as Amazon, when an event occurs so they can respond in accordance with the processes. Otherwise, the event goes

undetected and causes greater damage to the system.

Solution providers should implement monitoring systems that can automatically alert after an event has occurred. Common notification mechanisms include emails, ticketing systems, pagers, alarms, and short message service (SMS). Solution providers should have sufficient tools to respond to the incident in accordance with the response objectives.

Solution providers should implement response patterns when the event occurs. Documenting an incident is crucial. This preserves relevant information such as the incident description, remediation actions, and controls implemented to help prevent future recurrence. Per the Amazon DPP, Solution providers should document the incident, remediation actions, and corrective controls implemented to prevent recurrence. Additionally, creating documentation aids in escalating the issue to internal stakeholders,

partners, and affected parties.

Solution providers using NIST 800-53 may refer to **IR-4: Incident Handling**. Effective incident response means handling an incident in accordance with best practices and internal plans. Incident handling and incident response plans are interconnected. Each supports the other as Solution providers strengthen their incident handling and response capabilities. Control IR-4 supports this, and following each portion of the control helps the Solution provider to comply with the Amazon DPP. While not required, we recommend Solution providers consider implementing the control enhancements in this domain. These enhancements help Solution providers become well equipped to respond to different types of incidents and certify the health and success of their operations.

NIST control **IR-6: Incident Reporting** helps define the personnel in an escalation path. This is the chain of people that should remain

informed should an incident take place. Solution providers should define an escalation path to keep critical stakeholders and legal counsel informed. This enables them to assist the security team in taking action. Relevant stakeholders remain informed of the incident, its effects, and its status, all of which are necessary in the event that the Solution providers are legally or contractually obligated to notify an outside party. Solution providers should understand the legal and contractual requirements for reporting an incident, to whom, and when. Similarly, Solution providers should develop objectives to abide by those requirements.

Solution providers should validate that the escalation path and notification procedures include all parties with a legal or contractual right to know. For example, GDPR mandates that data controllers should notify the relevant supervisory authority within 72 hours after verifying that certain

types of personal data breaches have occurred. Similarly, the Amazon Data Protection Policy requires that Solution providers inform Amazon through email to security@amazon.com within 24 hours of detecting an incident.

Preserve evidence

Solution providers should verify that they are collecting, storing, and protecting logs that capture all critical actions within the environment. At minimum, these logs should contain:

- The success or failure of the event.
- The date and time.
- Access attempts.
- Data changes.
- System errors.

Solution providers with access to Amazon information should ensure that logs do not contain Personally Identifiable Information. Logs should be retained for reference in the case of a security incident. For a list of logging

requirements, refer to "Logging and Monitoring" in the [Data Protection Policy](#).

Solution providers should protect logs from accidental or intentional deletions by storing them in a secure location with access granted only to the required personnel. Log information is vital to understanding what, how, and when a system was compromised. Solution providers should preserve logs, drives, and other evidence by copying them to a centralized account.

Solution providers should develop and maintain a chain of custody to maintain the information's integrity by logging who accessed the information, to whom it was given, and all actions taken. These practices give Solution providers the ability to assert whether the affected systems were altered, and to provide assurance that the investigation's findings are accurate. Solution providers who follow the NIST 800-53 framework may refer to control **AU-10(3): NonRepudiation | Chain of Custody**.

While Audit and Accountability (AU) is not within the IR domain, this control can help define and maintain a chain of custody process. In addition to maintaining compliance with the Amazon DPP, a chain of custody can assist in taking action against an intruder in a court of law, if necessary.

Continuous review

Solution providers should thoroughly test, review, and regularly update their Incident Response Plan. Regular testing, review, and updates ensure Solution providers can quickly respond to and resolve security incidents. Amazon requires Solution providers to review and verify the plan every six months and after any major infrastructure or significant system changes. Such changes might include:

- **System.** System changes, such as developing new software, using new tools, or deprecating existing tools may increase the likelihood of potential issues.

- **Controls.**
Implementing new controls or experiencing control failures may affect the Solution providers' exposure.
- **Operational environments.**
Shifting from on-premise to cloud environments, or vice versa, may introduce new complexities in the systems. Solution providers should conduct risk assessments to understand the new risks that such a change may introduce.
- **Supply chain.**
Changes in the supply chain, such as changing hardware providers or changing contractor firms, may introduce new risks. For example, a particular hardware provider may be known to inform its customers of technical issue patches quickly, but a lower-cost competitor may not offer that service. In this case, the latter's customers should

account for the fact that they need to actively protect their infrastructure against common web exploits like SQL injection and implement those patches.

- **Risk levels.** Risk levels fluctuate due to the aforementioned factors. Solution providers should consider implementing an acceptable level of risk for the business and reviewing the incident response plan if that risk reaches its threshold.

Frequent reviews are also valuable. When Solution providers identify gaps in processes or tools during normal operations, they should address them promptly. These gaps may be self-identified or may occur after a major system change or incident. Solution providers should implement corrective processes and controls to detect and prevent future incidents. Afterward, Solution providers should update the incident

response plan to reflect the lessons learned and processes implemented.

After designing and building the incident response plan, Solution Providers should test it prior to an actual event occurring. Solution Providers should establish a regular cadence for conducting tabletop exercises - scenario-based walkthroughs where key stakeholders discuss their roles and responses to simulated incidents as well as operational simulations where the security team actively tests processes and tools. These exercises help reduce Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR), and satisfy Amazon's requirement to review and verify the Incident Response plan every six months.

For each scenario outlined, Solution providers should update the response plan accordingly and notify stakeholders if any changes arise.

Additional resources

- [Amazon SP-API Overview](#)

- [Amazon Acceptable Use Policy](#)
- [Amazon Data Protection Policy](#)
- [AWS Shared Responsibility Model](#)
- [AWS Security Incident Response Guide](#)
- [NIST SP 800-61r3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management, A CSF 2.0 Community Profile](#)
- [NIST 800-53 Rev.5: Security and Privacy Controls for Information Systems and Organizations](#)
- [National Vulnerability Database \(NVD\)](#)
- [Common Vulnerability Scoring System \(CVSS\)](#)

 Updated 18 days ago

Protect Amazon API Applications with

Safeguarding Sensitive Credentials →

Data
Retention
and
Recovery

Did this page
help you?

 Yes

 No

[Policies and Agreements](#)

[Privacy notice](#) | [Conditions of use](#)